

OWASP Juice Shop Security Assessment Report

Prepared By: Deepak M

Assessment Date: 06/07/2026

Target Application: OWASP Juice Shop

Environment: Kali Linux (VMware)

1.Executive Summary:

This report presents the results of a web application security assessment conducted against the OWASP Juice Shop application. The objective of the assessment was to identify security vulnerabilities, demonstrate their potential impact, and provide recommendations to improve the overall security posture of the application.

The assessment followed a structured penetration testing methodology, including reconnaissance, application mapping, vulnerability identification, exploitation, and validation. Various security issues were identified during the assessment, including authentication weaknesses, injection vulnerabilities, broken access control, sensitive information disclosure, client-side security flaws, and insecure application logic. Each identified vulnerability was validated through controlled testing to assess its exploitability and potential impact.

The findings documented in this report include a technical description of each vulnerability, supporting evidence, a CVSS v3.1 severity rating, the associated security risks, and practical remediation recommendations based on industry best practices and the OWASP Top 10.

It is important to note that OWASP Juice Shop is an intentionally insecure web application developed for security training, awareness, and penetration testing practice. All testing activities were performed within a controlled laboratory environment on authorized systems. No production environments or unauthorized third-party applications were involved during the assessment.

1. Objective:

The objective of this assessment was to perform a basic penetration test on the OWASP Juice Shop application to identify common web application security vulnerabilities. The assessment was conducted in a controlled lab environment for educational and demonstration purposes.

2. Scope:

Target Application

- OWASP Juice Shop

Assessment Type

- Black Box Web Application Penetration Testing

Environment

- Local Lab Setup (Kali Linux on VMware)

3. Testing Environment:

Component	Details
Operating System	Kali Linux
Virtualization	VMware Workstation
Target	OWASP Juice Shop
Browser	Firefox
Date of Assessment 06/07/2026	

4. Findings:

Finding 1 – SQL Injection in Login Page

Severity: Critical

CVSS v3.1 Score: 9.8

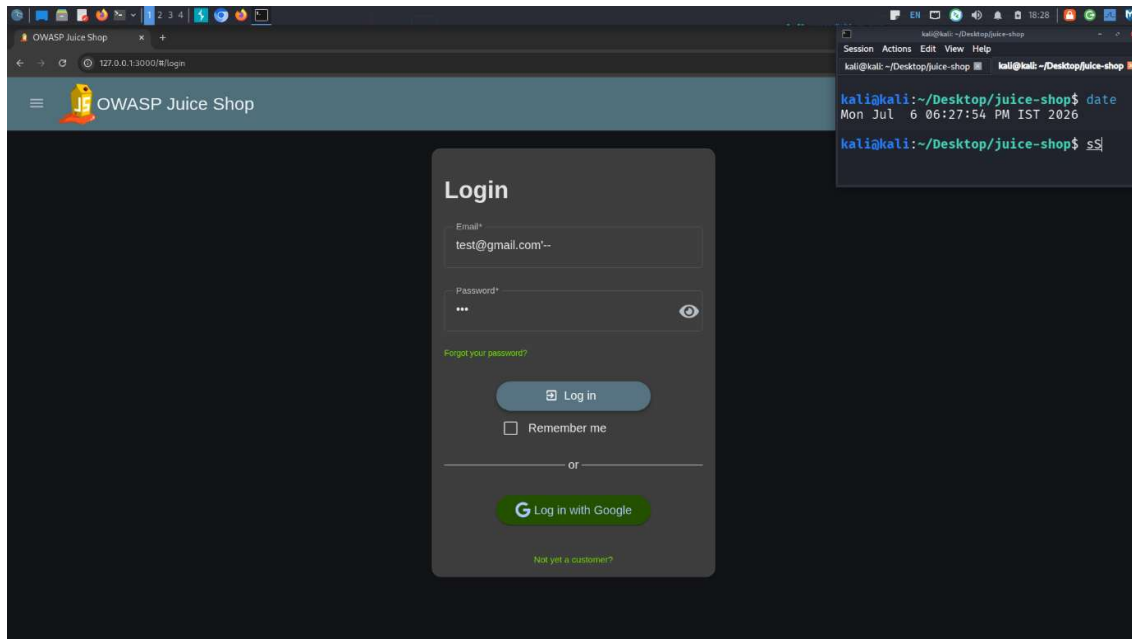
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

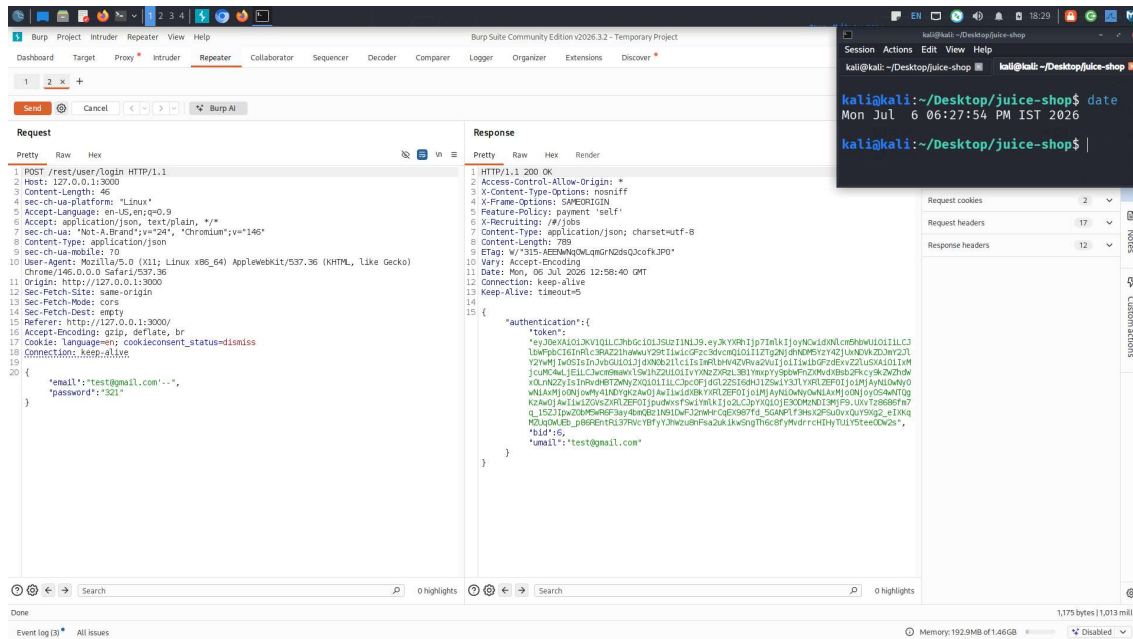
Description

The login page was found to be vulnerable to SQL Injection. By supplying specially crafted SQL input, authentication controls can potentially be bypassed.

Payload: test@gmail.com'--

Screenshots:





Impact

- Authentication bypass
- Unauthorized access
- Potential database compromise

Recommendation

- Use parameterized queries (Prepared Statements).
- Validate all user inputs.
- Avoid dynamic SQL queries.

Finding 2 – Cross-Site Scripting (XSS) in Product Search

Severity: Medium

CVSS v3.1 Score: 6.5

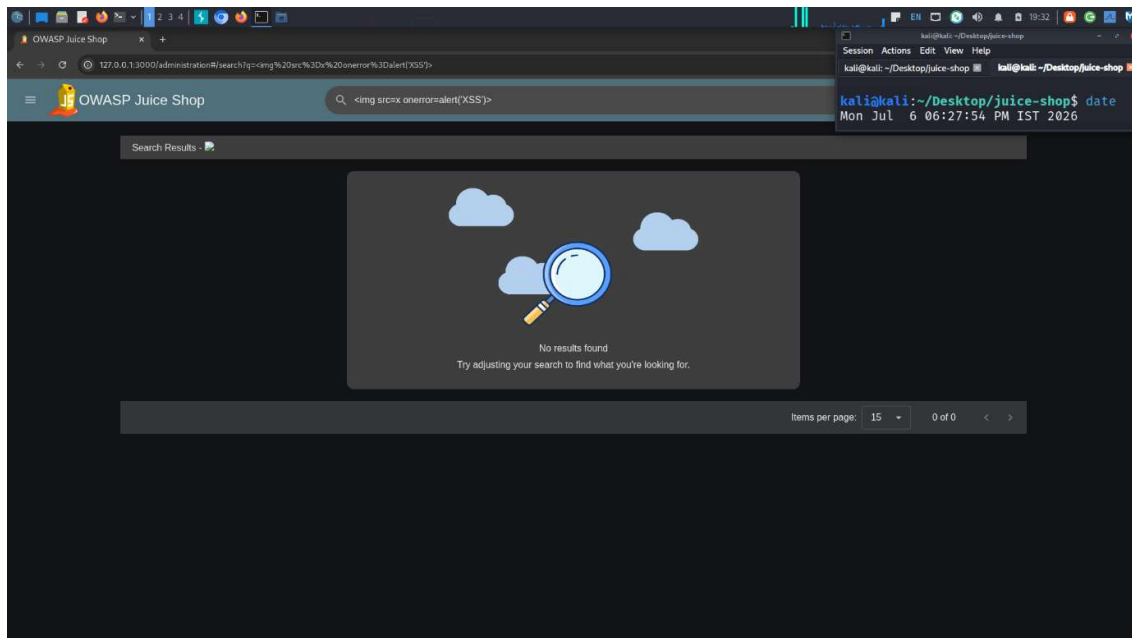
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:L

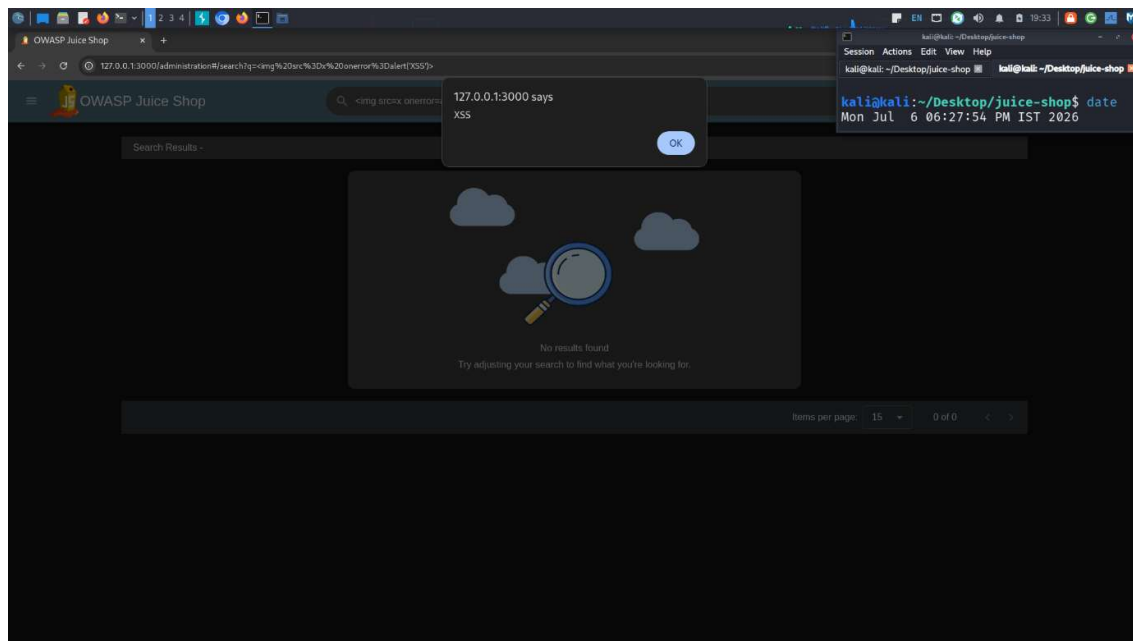
Description

The search functionality reflects unsanitized user input, allowing JavaScript execution within the user's browser.

Script: `<img src=x onerror=alert(XSS)>`

Screenshots:





Impact

- **Session hijacking**
- **Cookie theft**
- **Phishing attacks**
- **Client-side code execution**

Recommendation

- **Encode output.**
- **Sanitize user input.**
- **Implement Content Security Policy (CSP).**

Finding 3 – Information Disclosure through robots.txt

Severity: Medium

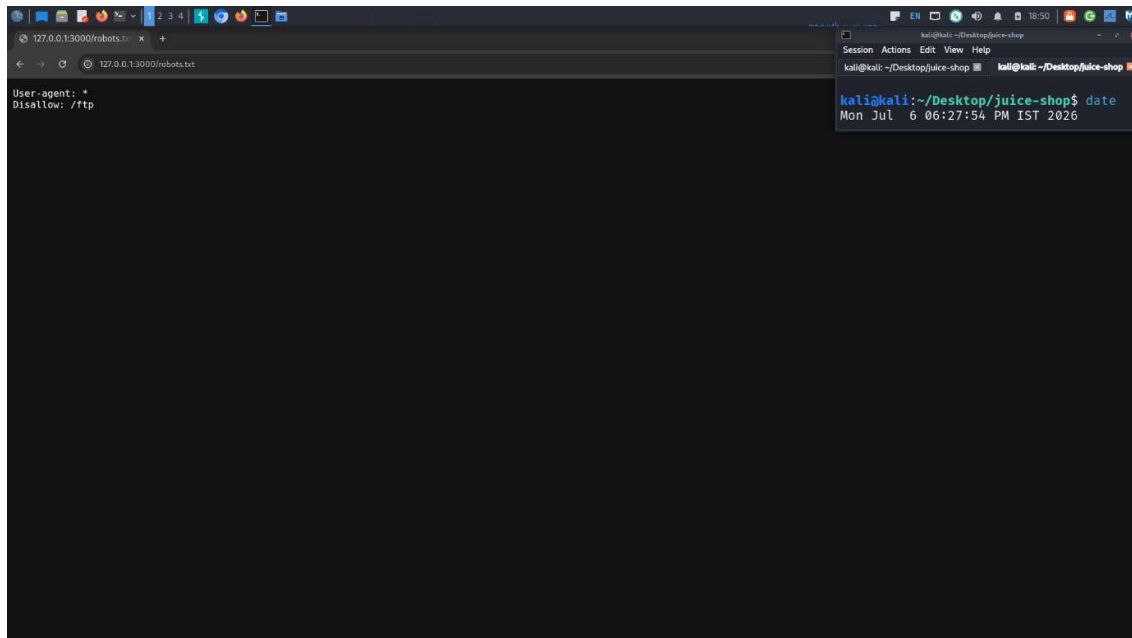
CVSS v3.1 Score: 5.3

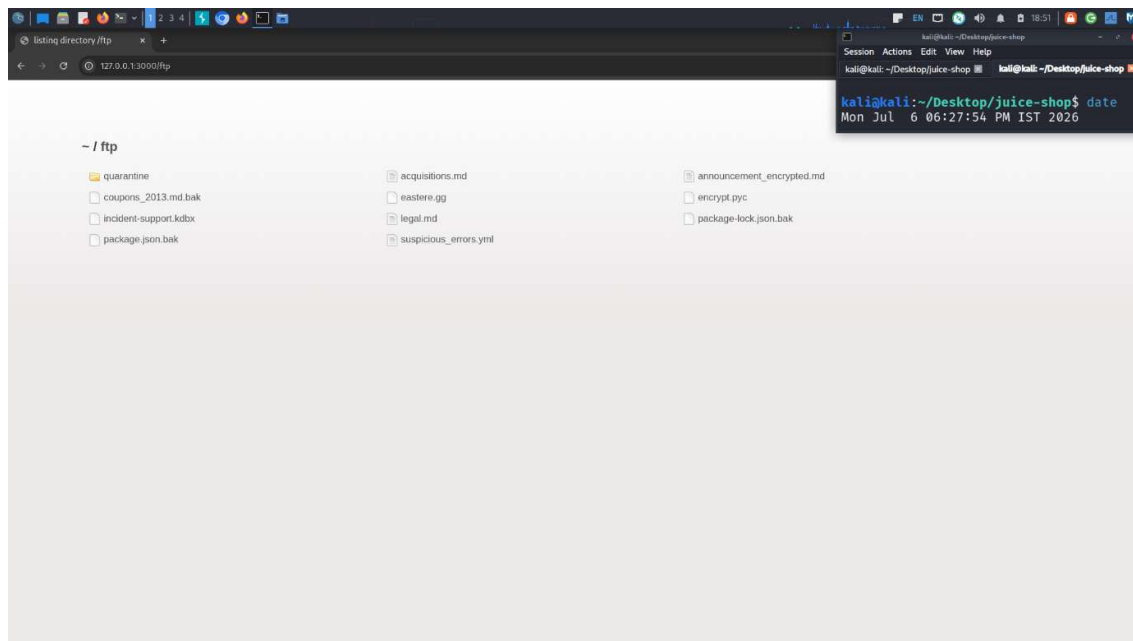
Vector: CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N

Description

The robots.txt file exposes hidden directory '/ftp' that should not be publicly discoverable.

Screenshots:





Impact

- Information disclosure
- Easier reconnaissance
- Increased attack surface

Recommendation

- Avoid exposing sensitive directories in robots.txt.
- Restrict access using authentication where necessary.

Finding 4 – Insecure Direct Object Reference (IDOR) in Cart

Severity: High

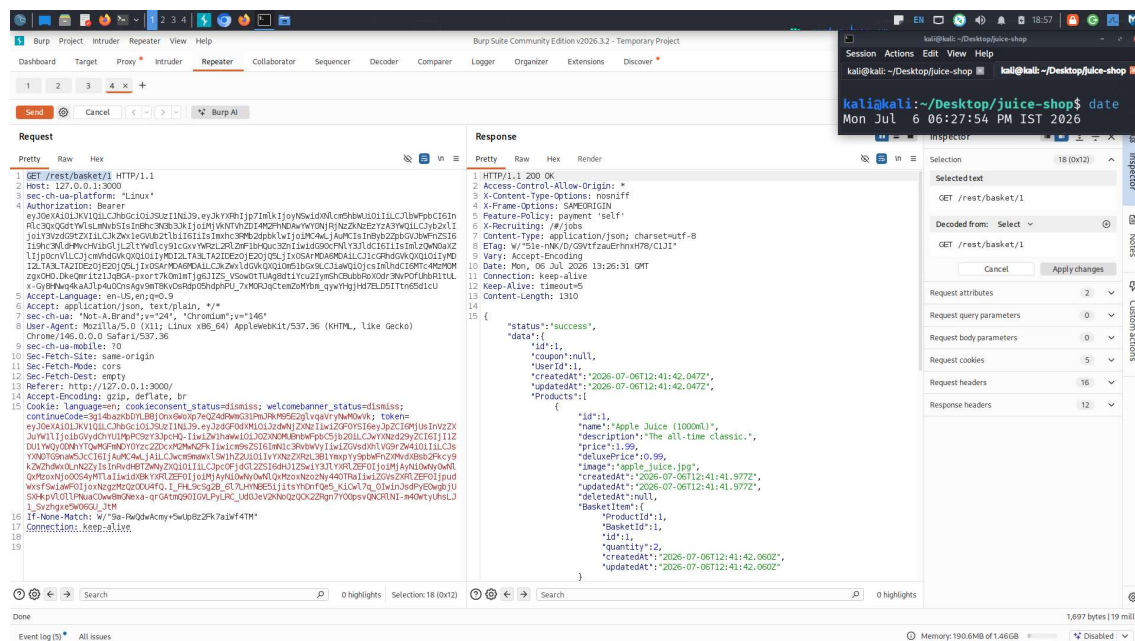
CVSS v3.1 Score: 7.6

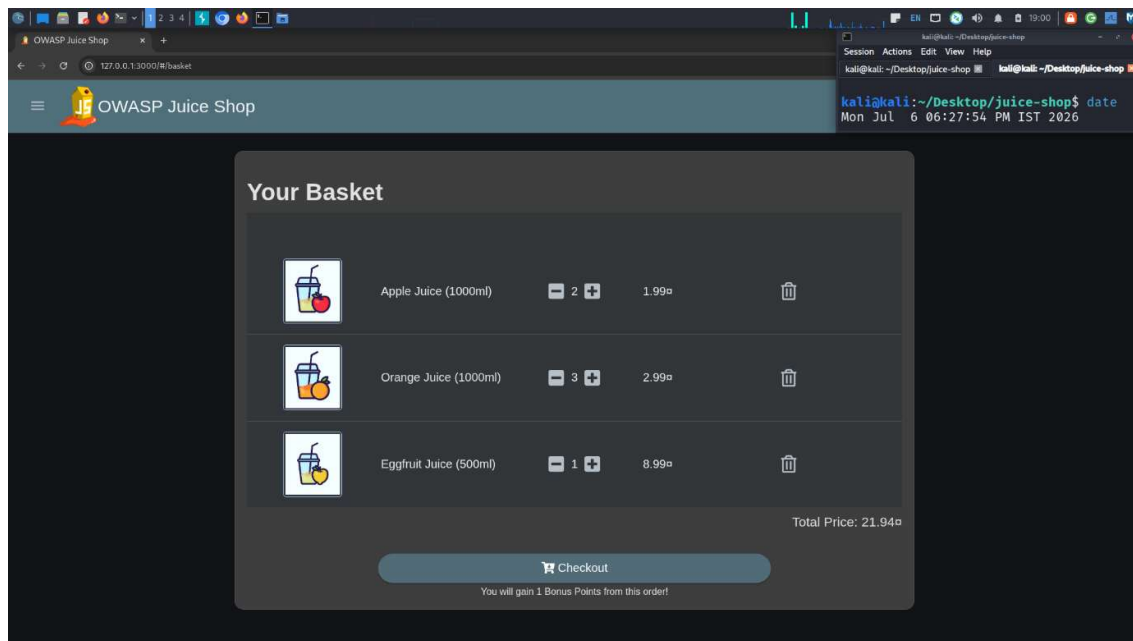
Vector: CVSS:3.1/AV:N/AC:L/PR:L/UI:N/S:U/C:H/I:L/A:L

Description

The application allows modification of object identifiers without proper authorization checks, enabling unauthorized access to another user's cart.

Screenshots:



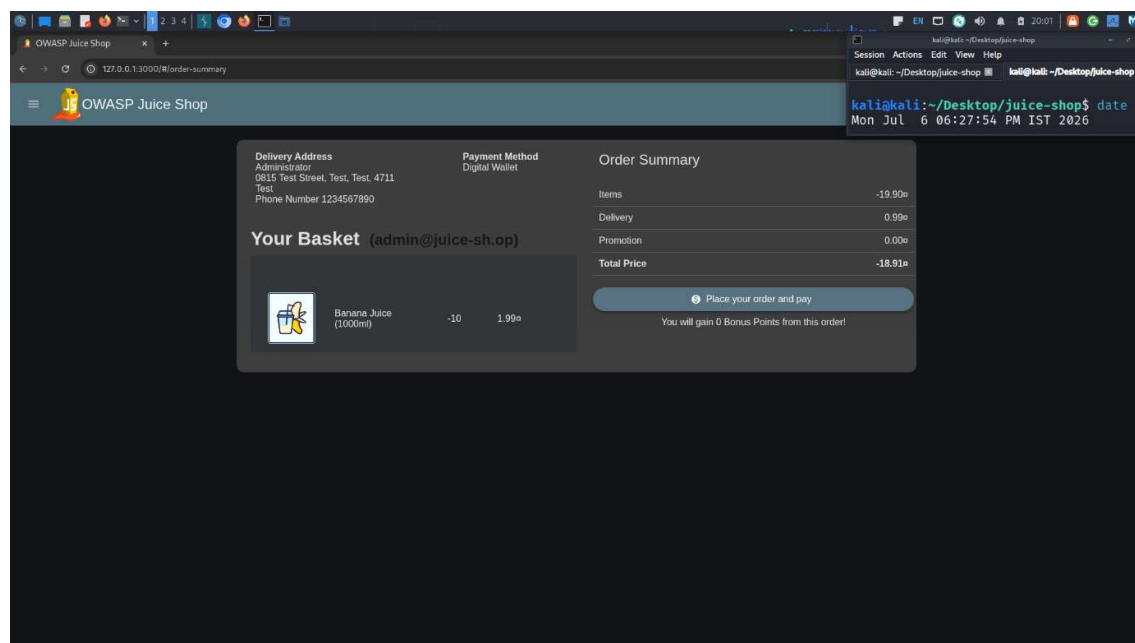


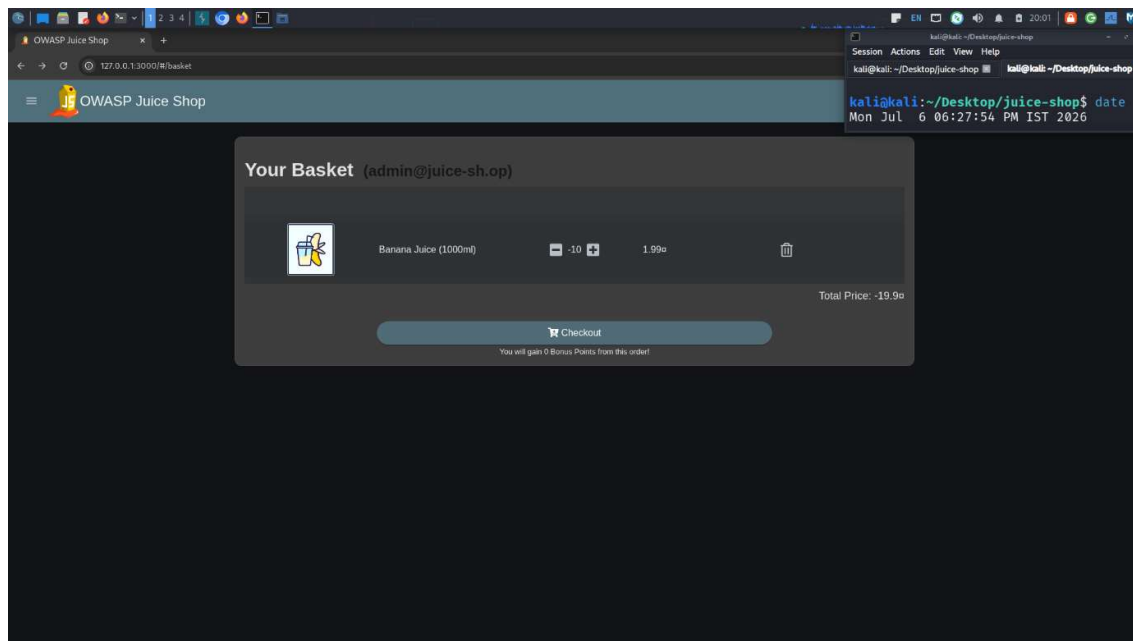
Impact

- Unauthorized data access
- Unauthorized data modification
- Privacy violation

Recommendation

- Perform server-side authorization checks.
- Never trust client-supplied identifiers.





Impact

- Business logic abuse
- Unexpected application behaviour
- Potential denial of service

Recommendation

- Validate all user inputs on the server side.
- Enforce minimum and maximum limits.
- Reject invalid values.

7. Conclusion

The assessment successfully identified five common web application security vulnerabilities within the OWASP Juice Shop environment. These findings highlight weaknesses related to authentication, input validation, authorization, and information disclosure.

Implementing the recommended mitigations would significantly improve the application's security posture and reduce the risk of exploitation.